

Decoding NCIIPC's Conformity Assessment Framework (CAF)

What IT & OT Leaders Must Know Now to
Secure India's Critical Information
Infrastructure (CII)



Copyright notice:

This white paper is the property of Payatu Consulting Pvt. Ltd. No part of it may be reproduced, distributed, or transmitted in any form or by any means, except as permitted below: You may print or download extracts to a local hard drive for your personal, non-commercial use. You may copy the content to individual third parties for their personal use, provided you acknowledge this white paper as the source. You may not, without our express written permission, distribute or commercially exploit the content. You may not transmit it or store it on any other website or in any other electronic retrieval system.

Copyright@ 2025 Payatu Consulting Pvt. Ltd. All Rights Reserved.



Table of Contents

1. Zoom Out First: What's Changing?	4
2. So, What Exactly is CAF?	5
2.1. Core Objectives of CAF	
3. The CAF Ecosystem: Five Schemes, One Purpose	7
3.1. Cybersecurity Management System Certification (CSMS)	
3.2. Inspection Scheme for IT & ICS	
3.3. Personnel Certification Scheme (CyberPros)	
3.4. Accreditation Scheme for Consultancy Organizations (COs)	
3.5. Accreditation Scheme for Training Bodies (TBs)	
4. Is CAF Mandatory?	15
5. What makes CAF Unique?	16
6. Preparing for CAF – Based on Who You Are	17
7. Final Word: This Is Not Just Another Compliance Exercise	18
8. References	19
9. How Can Payatu Help?	20
About the Author.....	21

1.0

Zoom Out First: What's Changing?

In a world where power grids and payment systems, turbines and telecom towers are increasingly bound by bytes, cybersecurity is no longer optional – it's existential.

To tackle the growing complexity and risk across both IT and OT systems in Critical Sector Entities (CSEs), India's National Critical Information Infrastructure Protection Centre (NCIIPC) in collaboration with the Quality Council of India (QCI) has developed a Conformity Assessment Framework (CAF).

Rather than being another policy document, this framework acts as a multi-layered national assurance system- built to assess, certify, inspect, accredit, and train stakeholders. It holistically addresses cybersecurity across people, processes, technology, and governance within and across CSEs, thereby fortifying cyber-resilience of India's Critical Information Infrastructure (CII).

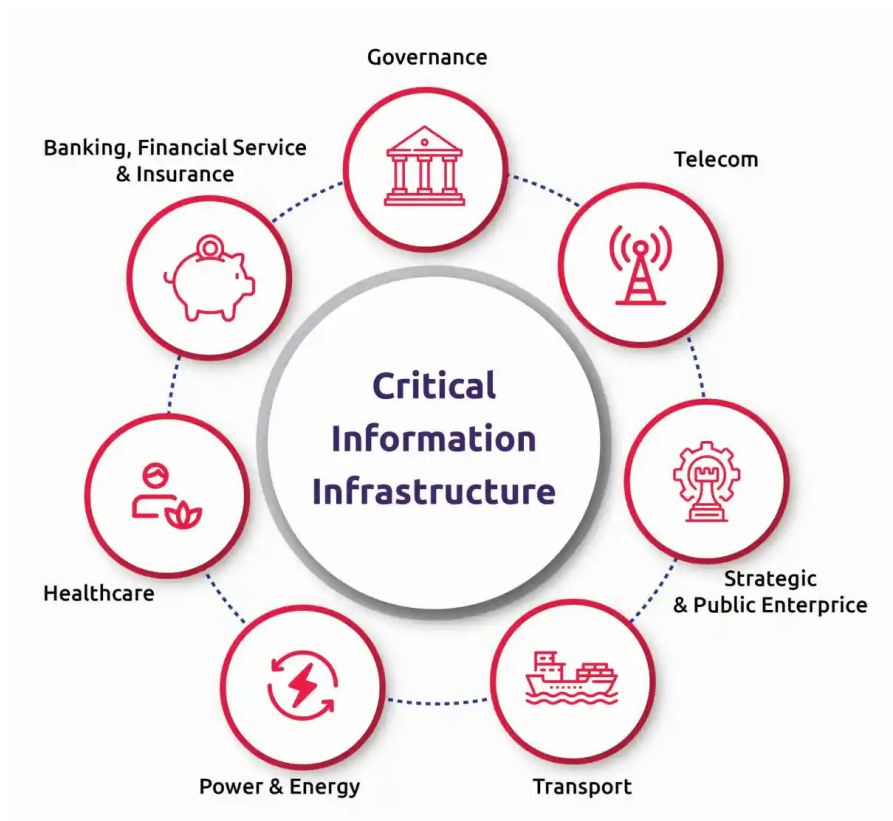
So, no – this isn't another checkbox standard. Instead, it's a structural shift in how CSEs will prove, improve, and sustain their cybersecurity maturity.

Whether you're running a power grid or consulting with a PSU, this framework is something you'll be navigating sooner rather than later.

2.0

So, What Exactly is CAF?

NCIIPC's CAF (NCIIPC Conformity Assessment Framework) for Cybersecurity of CSEs is India's new national-level cybersecurity assurance system to build trust and resilience across critical infrastructure like:



It's built on the philosophy that cybersecurity needs a verifiable backbone through institutionalizing national-level accreditation, inspection, competency assessment, and lifecycle certification of both systems and professionals.

CAF integrates global standards (ISO 27000, IEC 62443, NIST, CIS) with Indian legal and regulatory frameworks such as the IT Act 2000, NCIIPC directives, and CEA guidelines. Developed through multi-stakeholder input, it is tailored to India's Critical Information Infrastructure (CII), addressing ICS/OT complexities and national security needs. The framework aligns with the National Cybersecurity Reference Framework (NCRF), like how other countries incorporate their domestic laws and sector-specific nuances into national frameworks.

2.1. Core Objectives of CAF

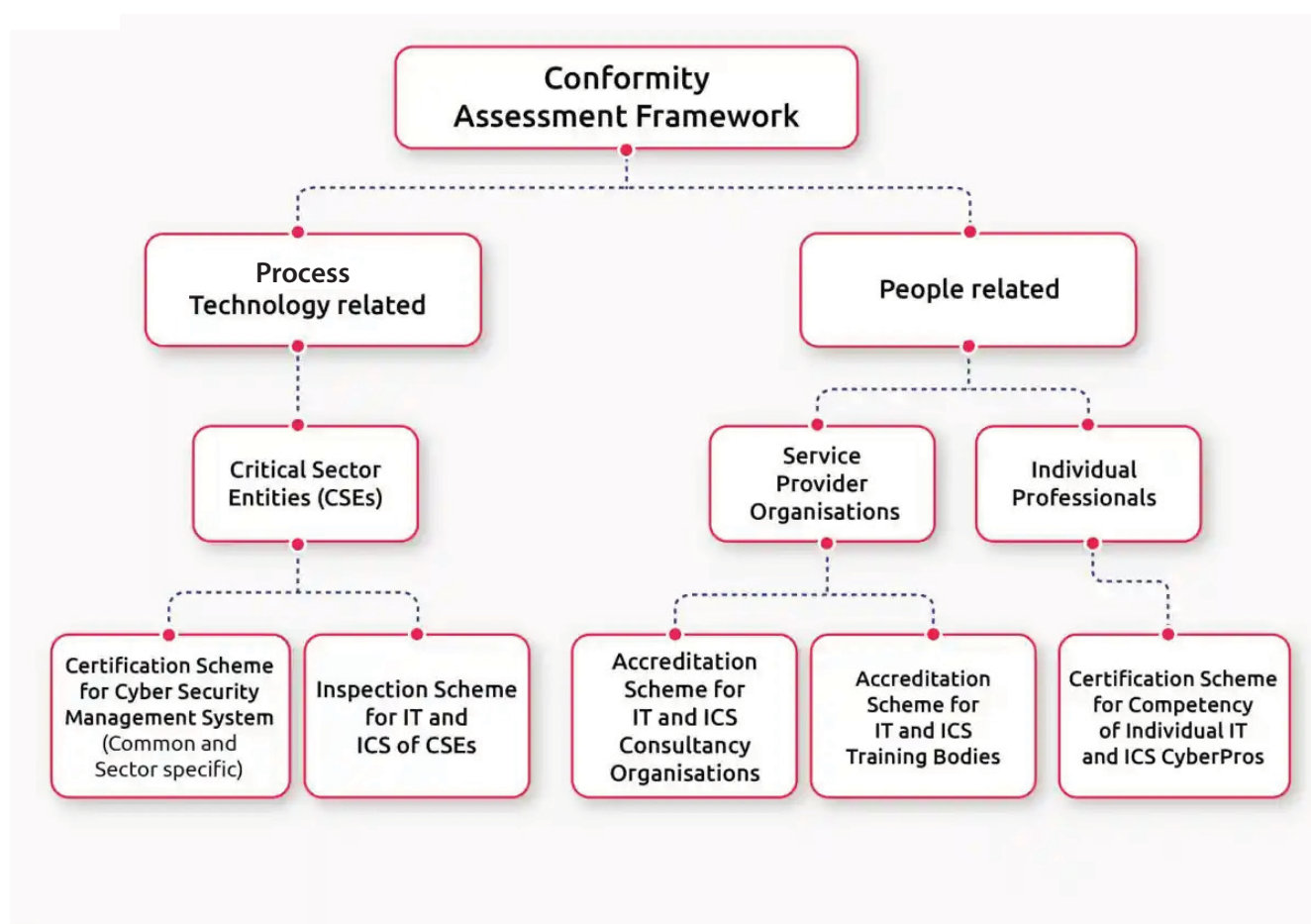
- ① Ensure independent cybersecurity conformity assessments of CSEs.
- ① Create an ecosystem of accredited experts, consultants, certifiers, and trainers.
- ① Certify professional competence in cybersecurity roles
- ① Provide transparent assurance mechanisms to regulators and the nation.



3.0

The CAF Ecosystem: Five Schemes, One Purpose

Unlike most frameworks that focus on audits or controls alone, CAF operates as a total ecosystem. It integrates five interconnected schemes, each with its own function and target audience. Here's how it unfolds:



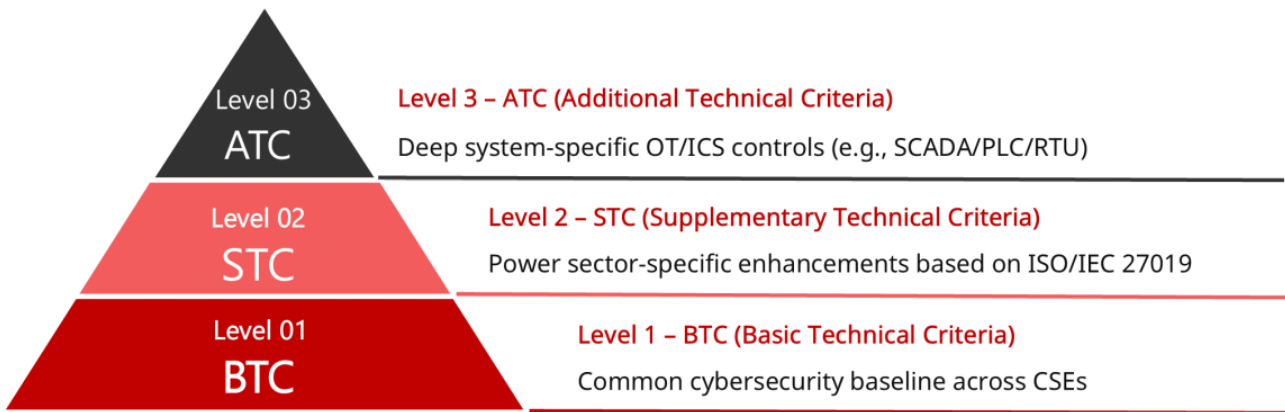
3.1. Cybersecurity Management System Certification (CSMS)

At the heart of this framework is the Cyber Security Management System (CSMS) scheme, which establishes a uniform and structured approach for building, auditing, and certifying cybersecurity maturity of CSEs at three levels.

At its core, the CSMS scheme sets forth the cybersecurity controls and governing processes of the Cybersecurity Management System. But more than that, it outlines in clear, auditable terms how organizations must demonstrate their conformance and how that conformance will be evaluated for formal certification.

Three-Level Architecture

The three ascending technical levels are BTC (Basic), STC (Supplementary), and ATC (Additional), which reflect escalating cybersecurity complexity and specialization.



3.1.1. Level 1 – BTC (Basic Technical Criteria)

As the foundational level of CAF, BTC defines a sector-agnostic cybersecurity baseline. It generically applies to both IT and OT environments and is universally applicable for all CSEs.

BTC is the foundational level of the Conformity Assessment Framework (CAF), addressing baseline cyber risks. This level is based on ISO/IEC 27001 with some additional requirements from ISO/IEC 27002:2022, Secure Controls Framework (SCF), and NIST SP 800-53.

Structurally, the BTC framework is divided into two parts:

Part A – Based entirely on IS/ISO/IEC 27001:2022, covering:

- ◆ Information security context, governance, planning, operations, and continuous improvement
- ◆ 93 detailed controls categorized into organizational, people, physical, and technological domains

Part B – CAF-specific additional controls to address Indian CII needs:

- ◆ C101: Cybersecurity governance
- ◆ C102: Embedded system and ICS/OT-specific controls
- ◆ C103: Intranet and internal network hardening
- ◆ C104: Cybersecurity Crisis Management Planning (aligned to national response standards)
- ◆ C105: AI and Autonomous Technology Risk Governance

BTC acts as a common minimum standard that helps align various sectors. It serves as the base for more specialized sectors (STC – Level 2) and system-specific (ATC – Level 3) requirements. Without BTC implementation and certification, higher CAF compliance is not permitted.

3.1.2. Level 2 – STC (Supplementary Technical Criteria)

STC focuses on sector-specific control additions to Basic Technical Criteria (BTC – Level 1) by introducing sector-specific cybersecurity controls for the Power Sector. These criteria are built utilizing ISO/IEC 27019:2017 (Energy Utility ISMS), IEC 62443-2-1, 3-2, and 3-3, NIST SP 800-82 Rev 2 (ICS Security), and India's CEA Cybersecurity Guidelines 2021.

Core Components of the STC

The STC has 11 clauses and 34 domain-Specific Controls control categories, which are divided into two parts:

Part A: Power Sector-specific Clauses

- ◆ Clauses aligned to ISO/IEC 27019 addressing assets, operations, access, and communication security.
- ◆ Mandatory for all CSEs in the power sector seeking Level 2 certification.

Part B: Additional CAF-specific Additions

- ◆ Additional security requirements that strengthen India-specific needs:
 - Incident response aligned with RLDC/SLDC coordination.
 - Enhanced governance for OT lifecycle
 - Controls addressing AI/autonomous operation risks
 - Physical and environmental hardening for substations and remote assets

STC ensures that the unique architecture and threat surface of the power sector are addressed directly. Controls are designed to work alongside BTC, meet sector-specific regulatory mandates, and align with India's national cybersecurity framework (NCRF)

3.1.3. Level 3 – ATC (Additional Technical Criteria)

The ATC (Additional Technical Criteria) is the third and most advanced layer of CAF. It is specifically crafted for Control Systems and OT environments in Power Sector Critical Sector Entities (CSEs). ATC is introducing vertical controls for ICS/SCADA environments. ATC introduces controls for the most complex and high-risk systems embedded in ICS/SCADA environments that conventional IT standards cannot sufficiently address.

The ATC framework is organized into 3 primary clauses supported by 3 detailed annexes and incorporates Zone and Conduit Risk Modelling (ZCR) as a core method for OT system risk management.

It is built upon and aligns with:

- ◆ IEC 62443-3-3: System security requirements and security levels
- ◆ IEC 62443-3-2: Risk-based zone and conduit identification and SL-T determination
- ◆ IEC 62443-2-1: Establishing and maintaining security programs for IACS
- ◆ NIST SP 800-82r3: Guidance on securing Industrial Control Systems (ICS), including SCADA and DCS environments
- ◆ Sectoral risk models from CEA and NTRO

Core Components of the Framework

Clause 1: CSMS for ICS

- ◆ Establish business rationale linking control system cybersecurity to uptime, safety, and business continuity
- ◆ Tailor cybersecurity management to ICS-specific availability and reliability requirements

Clause 2: CSMS Policy & Risk Framework

- ◆ Develop a tailored CSMS scope aligned to OT boundaries
- ◆ Conduct OT-specific risk assessments and define risk tolerance levels
- ◆ Define ZCRs (Zone & Conduit Requirements), SL-T, and mitigation controls

Clause 3: Review, Improve, Maintain

- ◆ Periodic audits, KPI evaluations, and CSMS upgrades based on evolving risks

Annex A: ZCR (Zone & Conduit Requirements)

- ◆ SUC demarcation
- ◆ Risk evaluation and SL-T setting
- ◆ Threat modeling across conduits, wireless, vendor, and field interfaces

Annex B: Control System Security Requirements

- ◆ Role-based authentication for PLCs, HMIs
- ◆ Application whitelisting
- ◆ Logging & monitoring of industrial protocols
- ◆ Jump server enforcement and OT-aware SIEMs



Annex C: Patch Management Requirements

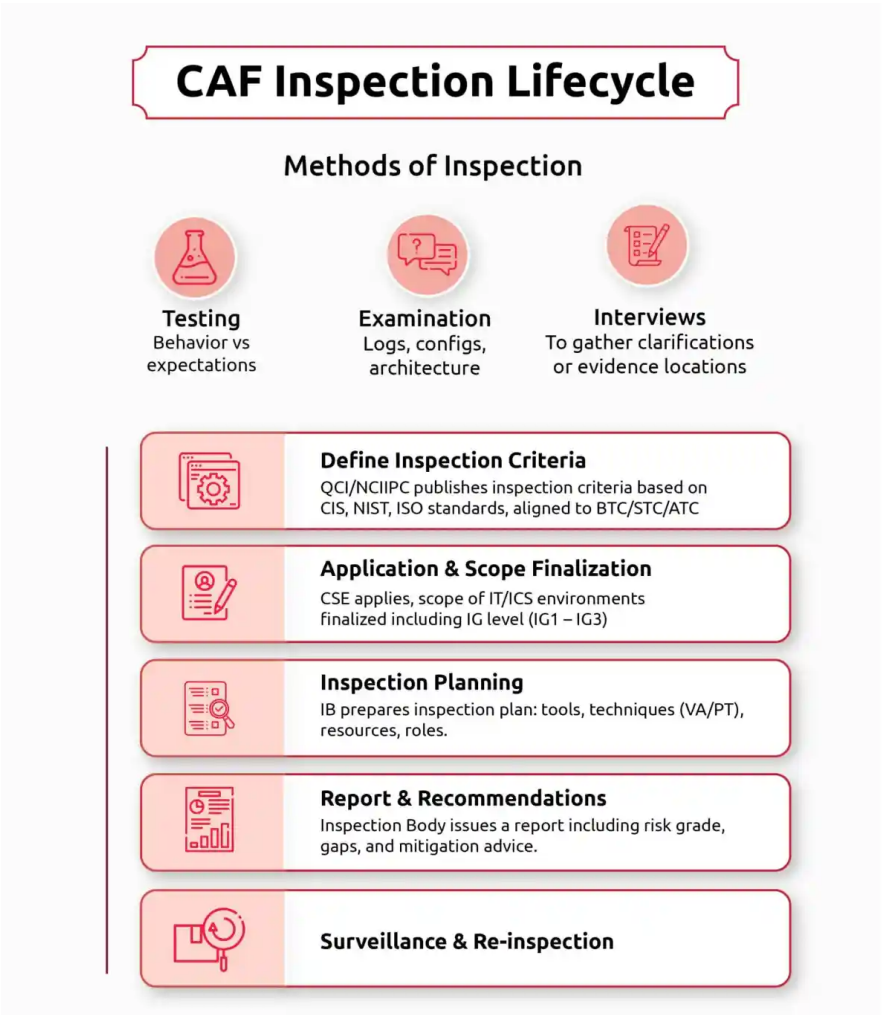
- ◆ Safe, vendor-approved update cycles
- ◆ Change management integration with control vendors
- ◆ Mitigation strategy for unpatchable legacy systems

ATC enables Power sector utilities operating ICS/SCADA/DCS to comply with CEA 2021, IEC 62443, and sectoral mandates, and encourages adoption of OT-focused cyber hygiene, training, and monitoring capabilities. ATC is only applicable once both BTC and STC are implemented and certified.

3.2. Inspection Scheme for IT & ICS

This isn't a casual checkup. QCI-accredited Inspection Bodies will perform independent, periodic technical inspections of both IT systems and industrial control environments. This will complement CSMS certification (which focuses on process and implementation).

Key Elements of the Scheme



3.2.1. Lifecycle of Inspection

This outlines the end-to-end process for technically validating a CSE's cybersecurity posture.

Covers:

- Defining inspection criteria on applicable controls and the organization's operational context.
- Managing Application & scoping the systems to be inspected
- Inspection planning & execution
- Reporting, surveillance, and re-inspection are mandated to ensure ongoing conformity and address newly emerging risks.

3.2.2. Inspection Methods:

The scheme defines three core inspection methods.

- **Testing** – comparing actual behavior with expected behavior under controlled conditions
- **Examination** – analyzing architecture, logs, configurations, etc.
- **Interview** – supporting inspection via discussions and clarifications

3.2.3. Inspection Controls Reference

The Inspection Scheme draws its control references from globally recognized cybersecurity baselines, tailored for both IT and ICS environments.

IT Controls:

Based on CIS v8.0 (18 critical controls like asset inventory, secure configurations, access control, vulnerability mgmt., logging, malware defense, etc.)

ICS Controls:

Based on CIS v7.0, adapted for OT (e.g., hardware/software inventory, audit logging in legacy devices, boundary defense, OEM constraints)

Each control is categorized by Implementation Groups (IG1, IG2, IG3) to guide maturity and applicability.

IG1 – Basic Hygiene:

Core controls like asset inventory, secure configurations, and anti-malware. Mandatory for all entities.

IG2 – Intermediate Controls: Adds centralized logging, MFA, and network segmentation baseline for CSEs.

IG3 – Advanced Defense: For high-risk environments (e.g., SCADA), including threat hunting, simulations, and

CII environments are expected to implement all three.

***Why it matters:** This scheme aligns with NCIIPC's mandate that CSEs should undergo regular third-party audits.*

3.3. Personnel Certification Scheme (CyberPros)

You can't defend CII without people who understand both Windows logs and Modbus coils. This scheme certifies individual professionals working in Critical Sector Entities (CSEs) to ensure they possess verified, role-specific knowledge and skills across both IT and ICS domains.

3.3.1. Certification is Based on:

- ◆ 19 Cybersecurity Domains (e.g., GRC, ICS Cybersecurity, System Security Admin, Cyber Defense)
- ◆ Specialization Areas (e.g., Secure Software Development, Network Security, Cyber Forensics)
- ◆ Three Expertise Levels:
 - F – Foundation:** Basic knowledge for entry-level roles
 - A – Advanced:** Applied skills and field experience
 - M – Master:** Strategic and leadership-level competence

3.3.2. Competency Profiles

Each certification is based on a defined competency profile, combining:

- ◆ **Knowledge Modules (KMs)** – Theoretical areas such as system security, network architecture, or OT protocols
- ◆ **Skill Modules (SMs)** – Practical areas like secure configuration, script development, and incident handling
- ◆ These modules are mapped to F/A/M tiers, enabling tailored evaluation based on the expected depth for that job function.

Delivered by: QCI-approved Personnel Certification Bodies (PrCBs)

3.4. Accreditation Scheme for Consultancy Organizations (COs)

This scheme accredits consulting firms with proven expertise in both IT and OT security to assist CSEs in implementing CAF-compliant systems.

3.4.1. Required Competencies:

- ◆ Performing CAF gap assessments and roadmap development
- ◆ SL-T mappings (Target Security Level)
- ◆ Performing Risk assessment aligned with IEC 62443, ISO 27001, NIST 800-30 alignment
- ◆ ICS security architecture design/review
- ◆ Technical control implementation/review
- ◆ Regulatory alignment for CEA, RBI, SEBI
- ◆ IT-OT risk convergence strategy

Who can apply: Indian consultancy organizations with a proven portfolio in IT and OT security consulting. These organizations

- ◆ Must be a registered legal entity with at least one year of proven cybersecurity consultancy experience.
- ◆ Maintain documented organizational structure, QMS (ISO 9001:2015), and ISMS compliance.
- ◆ Ensure confidentiality, integrity, and liability coverage via NDAs and risk management processes.

Why it matters: Consultancy firms that aren't accredited may soon be ineligible to support CSEs on compliance tasks.

Consultancy Organizations need to apply through QCI's PADD portal

3.5. Accreditation Scheme for Training Bodies (TBs)

To train the next-gen defenders, this scheme accredits institutes with structured programs in industrial cybersecurity. This is designed to ensure there's a pipeline of certified, skilled cybersecurity professionals equipped to handle India's CII protection challenges.

3.5.1. Required Capabilities:

- ◆ Legal registration as an entity delivering technical or cybersecurity training.
- ◆ Must have ISO 9001:2015 certification (Quality Management System).
- ◆ Must implement an ISMS, preferably aligned with ISO/IEC 27001.
- ◆ Must align with IS/ISO/IEC 21001:2018 (Educational Organization Management System).

"While formal certification to ISO 21001 is not mandatory, TBs must demonstrate adherence through structured training processes, learner feedback, and outcome tracking systems."

- ◆ Faculty with OT domain experience
- ◆ Curriculum covering
 - ICS cyber hygiene and governance, Network and system hardening (Windows/Linux), Protocol-level attacks (Modbus, DNP3, OPC-UA), Threat intelligence and IR in ICS Cyber-physical incident simulations
 - Training offerings are aligned to CAF roles (Foundation, Advanced, Master levels).

Did You Know?

"Only one training body is currently accredited under CAF as of May 2025 – and over 100+ CSEs are expected to undergo training."

4.0

Is CAF Mandatory?

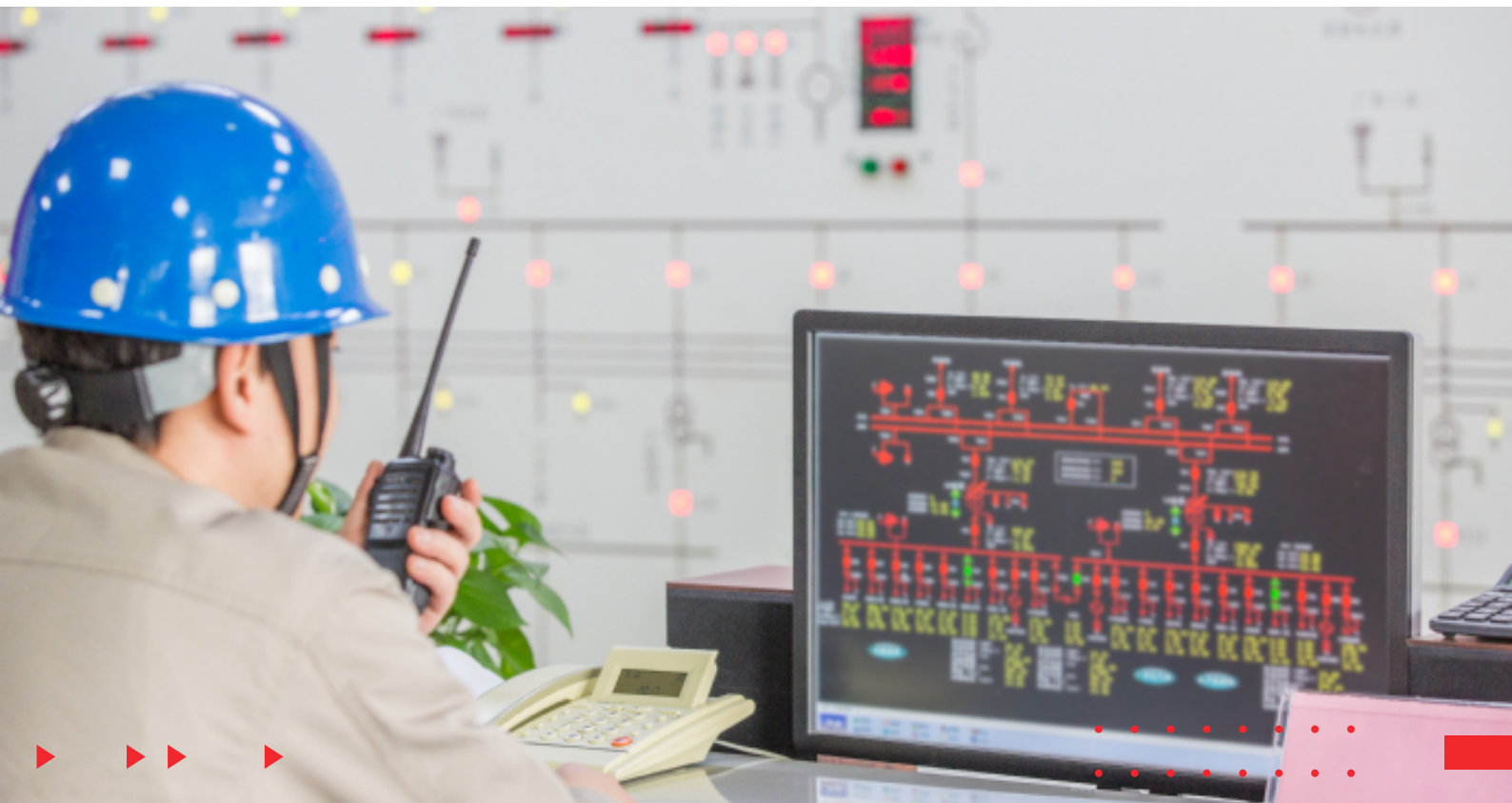
Not legally — not yet.

- ◆ Currently: Participation is voluntary. No direct legal mandate.
- ◆ But: NCIIPC already requires CSEs to undergo regular inspections — CAF provides the structure for that.

But in practice?

- ◆ Power Sector: Already aligning via CEA Cybersecurity Guidelines
- ◆ Finance, Defense, Telecom: Sector regulators (RBI, SEBI, DoT, MoD) are watching closely

So, while voluntary today, the direction is clear: Get certified or get left behind.



5.0

What Makes CAF Unique?

Aspect	Why It Matters
Covers IT + OT	Most frameworks focus on IT alone. CAF explicitly includes ICS, SCADA, PLCs , and legacy assets
Five Interlocking Schemes	Not just audits – includes inspection, training, personal certification, and consultancy
Built on 3-Level Architecture	BTC (Level 1), STC (Level 2), and ATC (Level 3) tailored to sectoral depth
India-Specific, Regulator-Ready	Built by NCIIPC + QCI for Indian critical infrastructure – not adapted from foreign mandates
Emphasis on Capability, Not Just Documentation	Requires skills, labs, tool chains, and operational readiness – not just policy binders

6.0

Preparing for CAF — Based on Who You Are

For Critical Sector Entities (CSEs)

- ◆ Map your IT/OT landscape against different levels of CAF controls
- ◆ Identify whether you're ready for CSMS Certification
- ◆ Onboard only QCI-accredited consultants, trainers, and inspectors
- ◆ Plan a readiness roadmap (CAF audits will require prep)

For Cybersecurity Consultant

- ◆ Get accredited — Prepare to apply under the consultancy scheme when QCI reopens it.
- ◆ Build capability in IEC 62443, OT hardening, IT-OT risk analysis
- ◆ Align offerings with all levels of CAF domains, including OT-specific services.
- ◆ Help clients with CAF gap analysis, inspection prep, and ATC alignment

For Training Providers

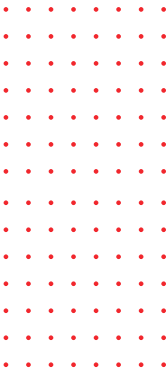
- ◆ Consider building a CAF-focused curriculum covering industrial protocol security, CSMS auditing, and incident response.
- ◆ If you're strong in training, pursue QCI's training body accreditation — only one is accredited now, and demand will surge

For Cybersecurity Professionals

- ◆ Consider certification under the CyberPros scheme (currently, five certification exams are listed only the TÜV SÜD academy, but availability is not their)
- ◆ Specialize in one or more tracks: GRC, system security, DevSecOps
- ◆ Be ready to show practical OT know-how — not just certs, but skills



7.0



Final Word: This Is Not Just Another Compliance Exercise

CAF is a rare beast — It's not just about compliance; it's deeply technical, sector-specific, and built from the ground up to actually uplift national cyber defense capabilities by defining a trusted ecosystem.

It's not perfect. But it's a start — and a good one.

Whether you're designing firewalls for substations, writing SOPs for PLC patching, or running OT pen tests, you'll want to be part of this ecosystem.

Because sooner than later, clients, regulators, or tender committees will ask:

“Are you accredited under CAF?”



8.0

References

<https://padd.qci.org.in/cyber-security-management-level-3/>
<https://padd.qci.org.in/inspection-scheme/>
<https://padd.qci.org.in/accreditation-scheme/>
<https://padd.qci.org.in/accreditation-scheme-training-bodies/>



9.0

How Can Payatu Help?

As a research-driven cybersecurity firm specializing in both IT and OT environments, **Payatu** can assist Critical Sector Entities in achieving CAF readiness through:

- ◆ CAF Gap Assessments aligned with BTC, STC, and ATC levels
- ◆ Zone & Conduit Risk Modeling using IEC 62443 standards
- ◆ CSMS Implementation & Audit Support for both IT & OT environments
- ◆ IT/OT Security Training & Skill Development

Whether you're managing substations, SCADA systems, or legacy ICS networks, **Payatu** brings deep technical expertise across compliance, threat modeling, and hands-on hardening for national infrastructure.

Ready to begin your CAF journey?

Reach out to us at sales@payatu.com or visit www.payatu.com

About the Author



Abhishek Pandey

Senior SCADA Security
Consultant - Payatu

Abhishek Pandey brings over seven years of research and industry experience, along with three years in academia, specializing in **Operational Technology (OT) and Industrial Control Systems (ICS) Cybersecurity**.

His expertise spans **risk consulting, vulnerability assessment, network architecture review, IT/OT integration security**, and compliance with globally recognized frameworks including **IEC 62443, NIST 800-82, and ISMS standards**.

Abhishek has contributed to critical cybersecurity projects across **India and the Middle East**, helping industrial enterprises and critical infrastructure operators strengthen their cyber resilience.

To learn more, connect with him on [LinkedIn](#).

About



Payatu is a research-powered cybersecurity consulting and training company delivering deep technical expertise across offensive security, secure design, and infrastructure risk assessments. It is present in over 20+ countries, and has domains spanning across IT, OT, Cloud, IoT, and embedded security. Payatu's comprehensive service offerings cater to modern security needs across critical infrastructure, applications, products, and engineering environments.

CORE SERVICE OFFERINGS

CRITICAL INFRASTRUCTURE & OT SECURITY

Payatu provides end-to-end OT/ICS cybersecurity services aligned with IEC 62443, NIST800-82, NCIIPC directives, and CEA Guidelines. Maturity and risk assessments, passive scanning, zone-conduit modelling, and secure architecture design are at the top of its capabilities. Clients are assisted in validating cybersecurity requirements during FAT/SAT, developing minimum baseline security standards (MBSS), and implementing asset inventory and monitoring solutions. Payatu's OT GRC advisory ensures governance frameworks are practical, compliant, and tailored to industrial environments.

PRODUCT & IoT SECURITY

Security assessments for embedded systems, IoT devices, and edge platforms, covering firmware, communication protocols, device-to-cloud data flow, and hardware-level protections are delivered exceptionally. The services also include threat modeling, fuzzing, exploitability testing, and secure product development advisory to ensure resilient design across all connected components.

WEB, MOBILE & CLOUD SECURITY

Payatu performs comprehensive VAPT of modern web, mobile, and cloud-native applications, including APIs and third-party integrations. Its coverage includes OWASP-ASVS mapping, business logic flaw detection, cloud misconfiguration reviews, and in-depth analysis of IAM, storage, and deployment risks across AWS, Azure, and GCP environments.

RED TEAMING & THREAT INTELLIGENCE

Payatu's red teaming services simulate real-world threats across IT and OT environments, emulating advanced adversaries through lateral movement and persistence. It also delivers cyber threat intelligence (CTI) services, including dark web monitoring, infrastructure threat feeds, brand monitoring, and targeted campaign tracking, to detect and respond to evolving risks.

DEVSECOPS & SECURE CODE REVIEW

Payatu embeds security directly into your development workflows through end-to-end DevSecOps consulting. This includes secure code reviews, IaC audits, configuration analysis, and pipeline security controls. The approach covers static code analysis, secure coding practices, and remediation guidance to empower development teams to shift security left.

TRAINING & LAB DEVELOPMENT

Payatu builds custom hands-on labs and training programs focused on IoT, ICS, offensive security, exploit development, and red teaming. Its offerings are designed for engineers, SOC teams, and practitioners and include both instructor-led and self-paced formats. With proprietary platforms and tailored ICS challenge labs, we deliver real-world, scenario-based cybersecurity learning environments.

CONTACT US

Payatu Security Consulting Pvt. Ltd.

✉ info@payatu.io

☎ +91-20-47248026

☎ +91-8319812123



www.payatu.com

